



What is Offline Cracking

- Attacker has hashes (not live login) and tries to recover original passwords.
- Work happens locally on attacker's hardware (no network requests).
- Uses wordlists, rules, masks, or brute-force to test candidate passwords.
- Faster and stealthier than online attacks — limited only by compute and hash strength.

What is John the Ripper

- An open-source, widely-used offline password cracking tool.
- Supports many hash formats and attack modes (wordlists, rules, incremental).
- Saves progress and cracked results (uses a pot file).
- Good for pentesting labs, and forensic recovery on authorized systems.

Why & Where We Use John The Ripper

- **Why:** to demonstrate password weaknesses, test password policies, and recover lost passwords in a controlled environment.
- **Where:** lab VMs, forensic investigations, authorized pentests, CTFs, and training platforms (TryHackMe/HTB).
- Helps show impact of weak/fast hashes and poor password hygiene.

How We Defend Against Offline Cracking?

- Use slow, memory-hard hashing (bcrypt, scrypt, Argon2) with proper cost settings.
- Apply unique salts per password and strong key-management (rotate keys if leaked).
- Enforce long passphrases and block common passwords (ban breached passwords).
- Limit damage: store minimal sensitive data, monitor for leaks, and require MFA for accounts.